Esercizio w15d1

1. Null Session

Cosa vuol dire Null Session

Una **Null Session** è una connessione anonima (senza nome utente né password) stabilita verso una risorsa condivisa di un sistema Windows tramite il protocollo **SMB** (Server Message Block) o **NetBIOS**. Sfrutta le condivisioni inter-processo (**IPC$**) per permettere a un attaccante di enumerare informazioni sensibili dal sistema remoto senza autenticarsi.

Sistemi vulnerabili e disponibilità in commercio

- **Sistemi vulnerabili:** Principalmente le versioni datate di Windows, tra cui **Windows NT**, **Windows 2000**, **Windows XP** e **Windows Server 2003**.
- **Stato commerciale:** Questi sistemi sono **fuori commercio** e non ricevono più supporto ufficiale (End of Life). Tuttavia, la vulnerabilità può ripresentarsi su sistemi moderni (Windows 10/11 o Server 2022) se le policy di sicurezza vengono configurate in modo errato o se sono attivi protocolli legacy per compatibilità.

Modalità per mitigare o risolvere

- **Restrizione accesso anonimo:** Configurare nel Registro di sistema o tramite GPO la chiave `RestrictAnonymous` impostandola a `1` o `2`.
- **Disabilitazione SMBv1:** Disattivare le versioni obsolete del protocollo SMB.
- **Firewalling:** Bloccare le porte TCP 139 e 445 a livello di perimetro.
- **Rimozione IPC$:** Impedire la creazione di condivisioni amministrative nascoste se non strettamente necessarie.

---

2. ARP Poisoning (ARP Spoofing)

Come funziona l'ARP Poisoning

L'**ARP Poisoning** consiste nell'invio di messaggi ARP (Address Resolution Protocol) falsificati all'interno di una rete locale (LAN). L'obiettivo è associare l'indirizzo MAC dell'attaccante all'indirizzo IP di un altro host (solitamente il Gateway/Router). In questo modo, il traffico destinato al router passerà prima dalla macchina dell'attaccante, permettendogli di intercettare, modificare o bloccare i dati (**Man-in-the-Middle**).

Sistemi vulnerabili

Tutti i sistemi che utilizzano il protocollo **IPv4** e si basano su **ARP** sono intrinsecamente vulnerabili. Poiché l'ARP è un protocollo "stateless" (senza memoria) e privo di autenticazione, la vulnerabilità non dipende dal sistema operativo, ma dalla logica del protocollo stesso. Sono quindi colpiti:

- Sistemi operativi (Windows, Linux, macOS, Android, iOS).
- Dispositivi IoT e stampanti di rete.
- Switch e router (se non protetti).

Modalità per mitigare, rilevare o annullare

- **Mitigazione (Prevenzione):**

  Dynamic ARP Inspection (DAI): Funzionalità degli switch che verifica la validità dei pacchetti ARP.

  Port Security: Limitare il numero di indirizzi MAC per porta sullo switch.

  ARP Statici: Configurare manualmente le tabelle ARP (difficile da gestire su larga scala).

- **Rilevamento:**

  Utilizzo di **IDS/IPS** (Intrusion Detection Systems) come Snort.

  Software specifici come **Arpwatch** o **XArp** che monitorano cambiamenti sospetti nei MAC address.

- **Annullamento:**

  Clear ARP Cache: Svuotare la tabella ARP dei dispositivi coinvolti (`arp -d` su Windows o Linux).

  Isolamento della porta dello switch dell'attaccante.

1. Scenario e Infrastruttura

L'attacco è stato configurato come un **Man-in-the-Middle (MITM)** all'interno di una rete locale (LAN).

- **Attaccante:** Kali Linux (Macchina Virtuale su VirtualBox).
- **Target (Vittima):** Host fisico Windows 10/11.
- **Gateway:** Router domestico (IP: 192.168.1.1).
- **Tipo di connessione:** Ethernet (Scheda con Bridge).

2. Configurazione della Macchina Virtuale

Per permettere l'intercettazione del traffico non destinato originariamente alla VM, sono state applicate le seguenti impostazioni critiche:

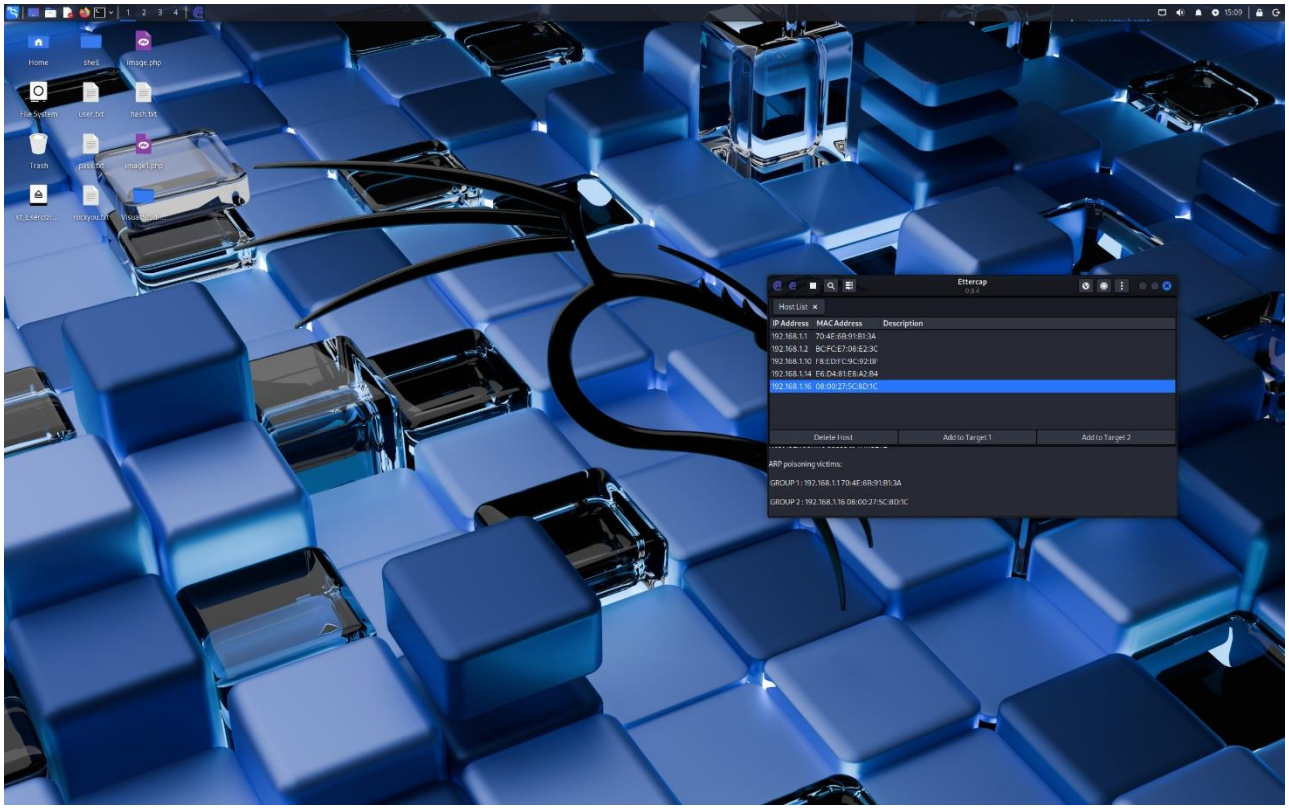
- **Network Bridging:** La VM è stata collegata direttamente alla scheda Ethernet fisica per ottenere un IP nella sottorete 192.168.1.x.
- **Modalità Promiscua:** Impostata su **"Permetti tutto"** nelle impostazioni di VirtualBox per consentire alla scheda virtuale di leggere i pacchetti destinati ad altri MAC address.
- **IP Forwarding:** Abilitato nel kernel di Kali tramite il comando: sudo sysctl -w net.ipv4.ip_forward=1 *(Essenziale per evitare il Denial of Service sulla vittima).*

3. Esecuzione dell'Attacco con Ettercap

È stato utilizzato **Ettercap** per l'avvelenamento della tabella ARP.

1. **Target 1:** IP del PC Fisico (192.168.1.2).
2. **Target 2:** IP del Gateway (192.168.1.1).
3. **Azione:** Attivazione dell'**ARP Poisoning** (Sniff remote connections).

Esito: L'avvelenamento è avvenuto con successo. Il comando arp -a sulla vittima ha confermato che l'indirizzo MAC del gateway era stato sostituito con quello dell'attaccante (Kali).



```
Interfaccia: 192.168.1.2 --- 0x13
  Indirizzo Internet    Indirizzo fisico      Tipo
  192.168.1.1           70-4e-6b-91-b1-3a     dinamico
  192.168.1.5           a6-aa-b4-b6-c9-3d     dinamico
  192.168.1.7           08-00-27-63-b0-05     dinamico
  192.168.1.9           20-fe-00-1a-e6-b4     dinamico
  192.168.1.10          f8-ed-fc-9c-92-bf     dinamico
  192.168.1.15          c0-e4-34-6b-09-59     dinamico
  192.168.1.255         ff-ff-ff-ff-ff-ff     statico
  224.0.0.2             01-00-5e-00-00-02     statico
  224.0.0.22            01-00-5e-00-00-16     statico
  224.0.0.251           01-00-5e-00-00-fb     statico
  224.0.0.252           01-00-5e-00-00-fc     statico
  239.255.255.250       01-00-5e-7f-ff-fa     statico
  255.255.255.255       ff-ff-ff-ff-ff-ff     statico

C:\Users\lupet>arp 'a

C:\Users\lupet>arp -a

Interfaccia: 192.168.56.1 --- 0xc
  Indirizzo Internet    Indirizzo fisico      Tipo
  192.168.56.255        ff-ff-ff-ff-ff-ff     statico
  224.0.0.2             01-00-5e-00-00-02     statico
  224.0.0.22            01-00-5e-00-00-16     statico
  224.0.0.251           01-00-5e-00-00-fb     statico
  224.0.0.252           01-00-5e-00-00-fc     statico
  239.255.255.250       01-00-5e-7f-ff-fa     statico
  255.255.255.255       ff-ff-ff-ff-ff-ff     statico
```

---

1. **Analisi delle Criticità e Debugging**

Nonostante il MITM fosse attivo, l'interfaccia grafica (GUI) di Ettercap non ha mostrato i pacchetti http o le credenziali in chiaro. Le cause identificate sono:

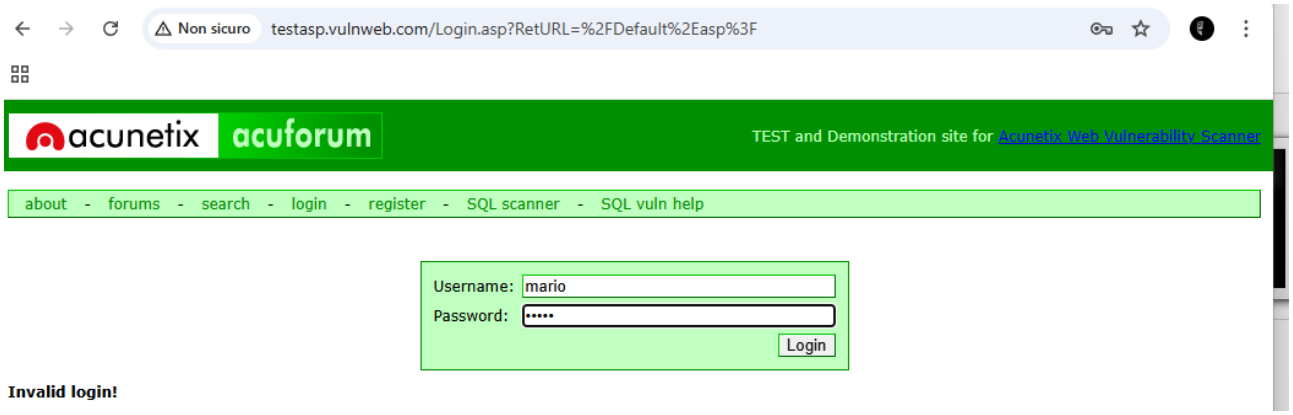
- **Obsoleto Matching dei Dissector:** Ettercap utilizza pattern predefiniti per identificare i campi di login (es. user, pass). Il sito target (testasp.vulnweb.com) utilizza campi specifici come tfUName e tfUPass, non riconosciuti automaticamente dal software.
- **Instabilità della GUI:** L'interfaccia GTK di Ettercap ha mostrato limiti nel rendering dei messaggi utente in tempo reale.

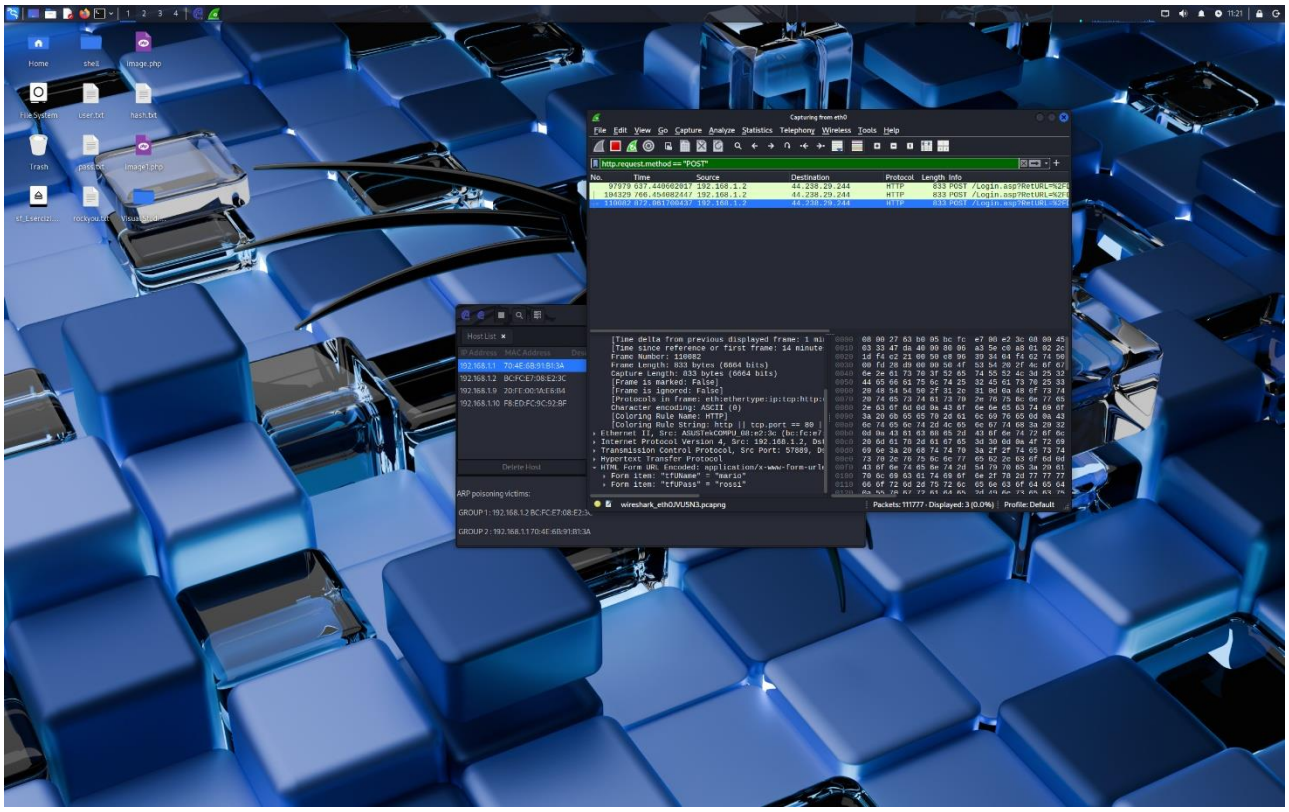
2. **Risoluzione tramite Wireshark**

Data l'inefficacia della visualizzazione in Ettercap, è stato utilizzato **Wireshark** per l'analisi granulare del traffico intercettato.

3. **Cattura:** Avviata sull'interfaccia eth0.

4. **Filtraggio:** Applicato il filtro http.request.method == “POST” per isolare i tentativi di autenticazione.
5. **Ricostruzione Dati:** Utilizzando la funzione **“Follow http Stream”**, è stato possibile visualizzare il contenuto del pacchetto inviato dal browser della vittima.
6. **Risultato:** Le credenziali inserite nel modulo ASP sono state estratte con successo dal corpo del pacchetto (HTML Form URL Encoded).





7. **Conclusioni**

Il test ha dimostrato che, sebbene Ettercap rimanga uno strumento valido per l'automazione dell'ARP Spoofing, l'analisi dei dati moderna richiede strumenti più sofisticati o manuali. L'integrazione di Wireshark è stata determinante per confermare il successo dell'attacco e recuperare i dati sensibili che Ettercap non era stato in grado di processare.

Facoltativo

1. Analisi della Vulnerabilità: SMB Null Session

Il servizio **Samba** (SMB) sul target Metasploitable è risultato configurato in modo permissivo, consentendo l'instaurazione di una **Null Session**. Questa condizione permette a un utente non autenticato di connettersi alla condivisione inter-processo IPC$ e interrogare il server.

---

2. Attività A: Accesso al File System tramite Symlink Traversal

In questa fase è stata sfruttata una configurazione errata che permette la creazione e il caricamento di link simbolici (Symlink) verso file esterni alla cartella condivisa.

- **Strumento:** smbclient
- **Target Share:** /tmp (Accesso in scrittura abilitato).
- **Metodologia:**

1. Accesso alla share tramite sessione anonima: smbclient //192.168.50.200/tmp -N.
2. Attivazione delle estensioni **POSIX** per la gestione corretta dei link Linux.
3. Creazione di un **Symlink** chiamato rootfs puntante alla radice del sistema (/) tramite Directory Traversal (../../..).

- **Risultato:** È stato possibile "evadere" dalla cartella /tmp e navigare nell'intero file system del server.

- **Esfiltrazione:** Tramite il link creato, è stato letto il file **/etc/passwd**.

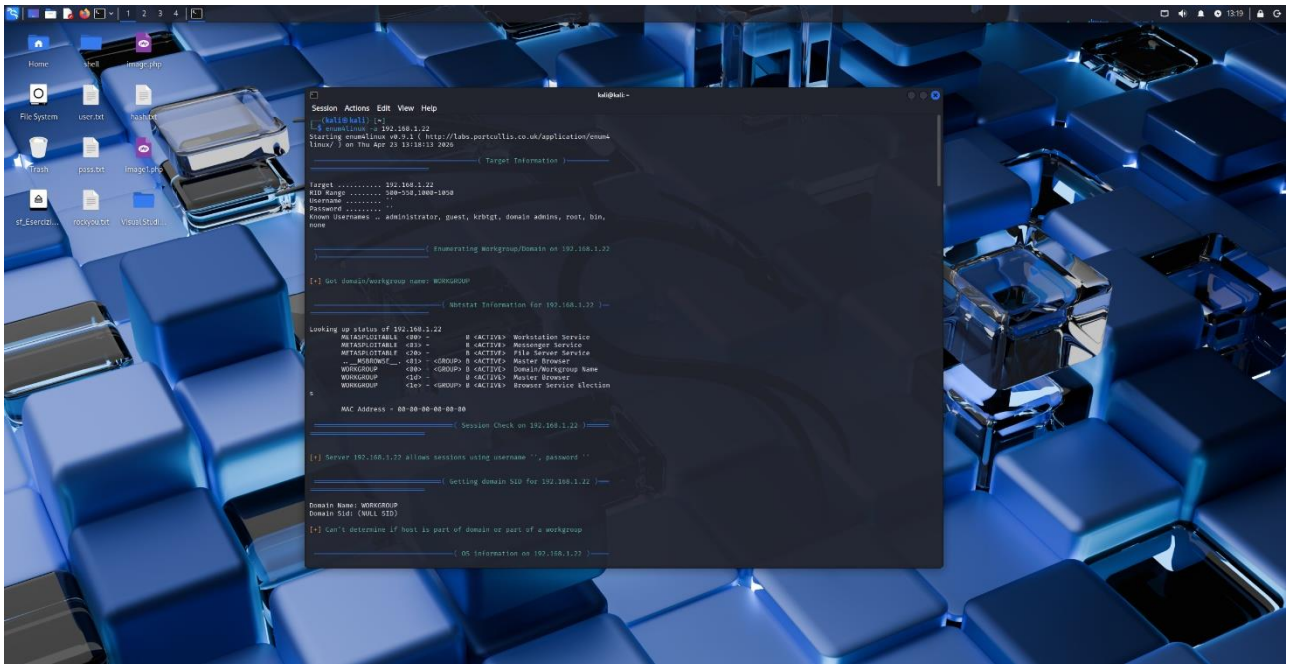
  - *Nota tecnica:* Il file ha confermato l'elenco degli utenti, ma ha mostrato che le password non sono conservate in chiaro (presenza del flag x), indicando che sono memorizzate in /etc/shadow.

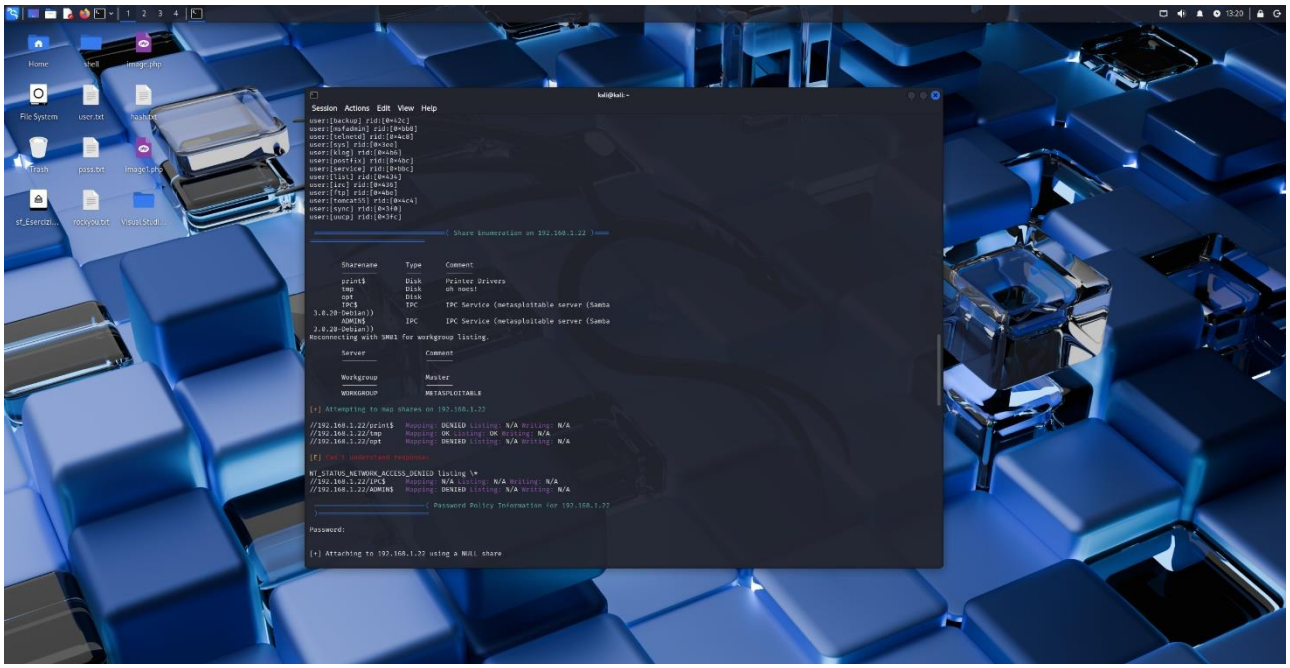
---

3. Attività B: Enumerazione Automata del Target

Dopo la fase di exploitation manuale, è stata condotta un'attività di ricognizione approfondita per mappare la superficie di attacco del server.

- **Strumento:** enum4linux
- **Comando utilizzato:** enum4linux -a 192.168.50.200
- **Dati estratti:**
  - **User Enumeration:** Lo strumento ha estratto con successo l'elenco completo degli utenti di sistema (es. root, msfadmin, user, service) sfruttando il RID cycling via Null Session.
  - **Share Enumeration:** Conferma dell'accessibilità delle condivisioni IPC$, ADMIN$ e delle cartelle scrivibili.
  - **OS Discovery:** Identificazione precisa del sistema operativo e della versione di Samba in uso.





---

4. Conclusioni e Valutazione del Rischio

Le attività hanno dimostrato una criticità di livello **Alto/Critico**.

1. **Impatto:** Un attaccante non autenticato può non solo ottenere una lista accurata di nomi utente (utile per attacchi di forza bruta), ma può anche leggere file di sistema riservati.
2. **Rilevanza del file /etc/passwd:** Sebbene non contenga le password in chiaro, la sua lettura permette di mappare la struttura del server e identificare account privilegiati.
3. **Risoluzione:** Per mitigare queste falle, è necessario:
    - Disabilitare l'accesso anonimo (Null Session) su SMB.
    - Configurare Samba con follow symlinks = no e wide links = no.
    - Applicare il principio del "minimo privilegio" alle condivisioni di rete.